KANKPA Arafate
ID CIN : **FIT/MAR26/CS7299**

TASK 1

FUTURES_CS_01 - Rapport d'évaluation des vulnérabilités d'un site web en ligne

A propos de la tache

Aujourd'hui chaque entreprise possède un site web mais la plupart ne sont pas sécurisés
Les petites entreprise starts up et agences ont souvent tendance à :

- Utiliser des plugins ou des Framework obsolètes
- En –tête de sécurité mal configurer
- Exposer des informations sensibles sans le savoir

Les clients ne demandent généralement pas de piratage, ils demandent des éclaircissements pour voir si leur site web est sécurisé, les risques et les corrections a faire

OBJECTIF

- Site web public pour identifier les failles de sécurité courante
- Classer les risques de manière adaptée aux entreprises
- Expliquer clairement les problèmes sans jargon technique excessif
- Proposer des mesures collectives pratiques
- Présenter l'ensemble des éléments dans des rapports d'Audi professionnel

PORTE ET ETHIQUE

Le respect des règles éthiques strictes
Autorisé

- Page publique uniquement
- Balayage passif
- Vérification d'enquête
- Analyse de configuration

Interdit

- Contournement de connexion
- Exploitation
- Attaque par force brute
- Attaque par déni de service
- Toute activité susceptible de nuire au site web

OUTILS

- NMAP: analyse de base des ports et des expositions
- OWASP ZAP (Analyse passive) : identifier des vulnérabilités sans attaquer
- OUTILS DE DEVELOPPEMENT DU NAVIGATEUR : inspecter les en-tête , les cookies et les problèmes coté client

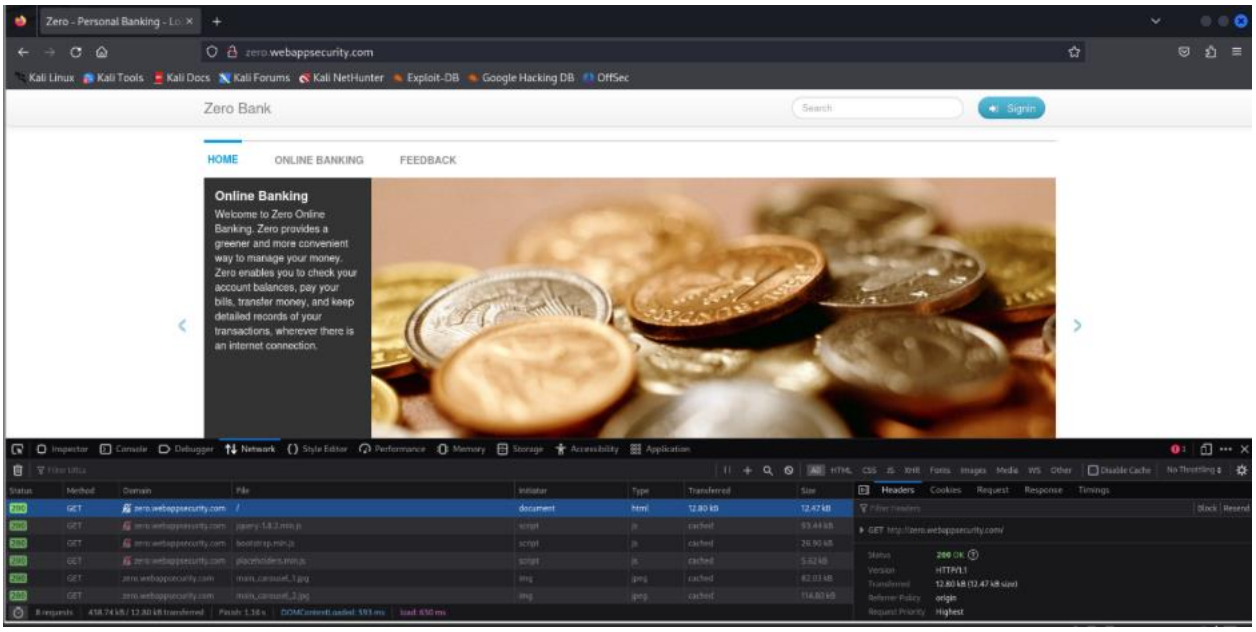
TRAVAIL A FAIRE

1. Sélectionner un site web public
2. Effectuer une analyse en lecture seule : identifier les services exposés ; vérifier les en-tête de sécurité ; détecter les composants obsolètes
3. Résultats du document : le problème ; importance ; niveau de risque
4. Classement des risques : Faible / Moyen / Elevé
5. Proposer les mesures correctives claires : des solutions pratiques qu'une entreprise peut comprendre

COMMENCEMENT DU TRAVAIL

A la base je voulais utiliser le site d'un ami mais il pourra avoir des problèmes d'hébergement, c'est dire même s'il est d'accord l'hébergeur lui n'a pas donné son accord et du coup quand je vais lancer un scan avec NMAP, j'envoie des centaines de requêtes par seconde et les systèmes de sécurité de vont détecter cela comme une attaque et
éviter de prendre le risque de casser son site donc je me suis dirigé vers un site web bien légal : http://zero.webappsecurity.com

Il s'agit d'une fausse banque en ligne. Avant même de cliquer sur la touche F12 on remarque la toute première vulnérabilité du site juste en le regardant (l'adresse commence par http:// et non https://) , cela signifie que le site n'a pas de certifications SSL/TLS
Risque : élevé pour un site bancaire
Correction : installation d'un certificat SSL et forcer la redirection a HTTPS
Outils de développement du navigateur : ce qui manque a l'en-tête



F12 ouvrir l'outil

- Network puis réactualiser la page ctrl+R
- Les lignes apparus = discussions avec le serveur pour afficher la page
- La toute première ligne on clique sur en tête ou header : c'est là que le serveur donne ses consignes de sécurité au navigateur

Avec ce que nous voyons dans header (l'en-tête) nous allons traduire ces données

FAILLE 1 : Divulgation d'Information sur le server
Dans la partie Header (en-tête) la ligne : server : Apache-coyote/1.1

- PROBLEME : Le serveur bavarde vraiment, il annonce publiquement à tout le monde le logiciel exact et la version qu'il utilise pour fonctionner

- IMPORTANCE : c’est comme si une banque affichait son coffre-fort sur sa porte d’entrée accompagné de la marque et l’année. Un pirate n’a plus qu’à chercher les failles connues de cette version précise pour attaquer
- RISQUE : Moyen, car elle donne juste les plans de la maison aux cambrioleurs, ce n’est pas une faille qui permet de pirater directement
- CORRECTION : Configurer le serveur web pour qu’il masque sa version. L'en-tête devrait simplement afficher Server : Apache ou ne rien afficher du tout

FAILLE 2 : Mauvaise configuration du partage de ressources
La ligne : Acces-Control-Allow-Origin : *

- PROBLEME : Le symbole * (astérisque) veut dire tout le monde. Cet en-tête dit que n’importe quel autre site web sur internet a le droit de lire les données affichées par ce serveur. Pour un site bancaire ou une entreprise c’est très catastrophique
- IMPORTANCE : Si un client est connecté a sa banque et qu'il visite en même temps un site malveillant, ce site malveillant pourrait utiliser cette faille pour lire en cachette les données du client (comme le solde de son compte)
- RISQUE : Elevé
- MESURE CORRECTIVE : Remplacement de l’astérisque par le nom de domaine exact de l’entreprise. Seul le serveur a le droit de lire lui-même ses données

FAILLE 3 : Absence de bouclier de sécurité
(En-tête manquant)
Le danger ne vient pas de ce qui est ecrit mais de ce qui manque, dans la partie (header) il manque des en-têtes de sécurité qui devraient s’y trouver.

- PROBLEME : Le site n’ordonne pas au navigateur (firefox) d’activer ses boucliers de sécurité. Par exemple il manque l’en-tête X-FRAME-OPTIONS
- IMPORTANCE : Sans X-FRAME-OPTIONS, Un pirate peut prendre le site de l'entreprise et l'afficher de manière invisible par son propre site obsolète, le client croit cliquer sur un bouton inoffensif mais il pique en réalité sur le site de la banque piégée (c'est la traque du détournement de clic)
- RISQUE : élevé
- MESURE CORRECTIVE : Ajouter les entêtes de sécurité standard dans la configuration du site : Notamment x- frame- options : DENY (qui interdit de superposer le site ailleurs) et content- Security- Policy(qui bloque l'exécution des virus sur la page)

Solutions pratiques qu’une entreprise peut comprendre

1. Sécuriser la communication des clients (Probleme du https) : Actuellement le site web n'est pas sécurisé et n'est pas chiffré il peut utilise http au lieu de https cela signifie que si le client se connecte à son compte bancaire depuis un réseau public un individu malveillant on peut intercepter son mot de passe

- Solution pratique: faire une acquisition d’un certificat SSL/TLS ; demander a l’equipe technique de l’installer sur le server web

2. Renforcer l’en tete de sécurité : Le site web a omis d'activer les boucliers de sécurité intégré au navigateur (Firefox) sans cela des fraudeurs peuvent masquer votre site derrière de temps invisible sur un autre site piégé des clients

- Solution pratique : Ajouter des instructions sites dans un fichier de configuration du serveur ; corrigé la politique de partage en remplacant l’ autorisation globale Par le nom de domaine strict de l'entreprise

NMAP

```
kali2026@KALI: ~
┌──(kali2026㉿KALI)-[~]
└─$ nmap -Pn -sV zero.webappsecurity.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 18:24 CEST
Nmap scan report for zero.webappsecurity.com (54.82.22.214)
Host is up (0.20s latency).
rDNS record for 54.82.22.214: ec2-54-82-22-214.compute-1.amazonaws.com
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE  VERSION
80/tcp   open  http     Apache Tomcat/Coyote JSP engine 1.1
443/tcp  open  ssl/http Apache httpd 2.2.6 ((Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e
 mod_jk/1.2.40)
8080/tcp open  http     Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.55 seconds
```

1. Utilisation d'un composant obsolète (ports 443 et 80)
- Problème : Nmap Que le le port 443 tourne avec Apache httpd 2.2.6 et Open SSl 0.9.8e . Ce sont des versions de logiciel extrêmement vieilles
- Important : c'est une faille des plus critiques d'une entreprise d'une avoir ces enseignes versions donc cette dizaine de de public documentées sur internet
- Niveau de risque : élevé
- mesure corrective : prise doit planifier en urgence une mise à jour complète de son infrastructure serveur pour utiliser la dernière version stable d'Appache et OpenSSl

2. Exposition d'un port de développement/test (port 8080)
- Problème : le port est ouvert au public et expose un service Appche
- Imprtance : Laisser un port test ouvert sur internet augmente inutillement la surface d'attaque de l'entreprise .Les entreprises de développement sont souvent moins sécurisées et garde parfois les mots de passe par défaut
- niveau de risque : moyen
- mesures correctives: bloquer l'accès au port depuis l'extérieur à l'aide du pare-feu du serveur

FUTURES CS 02 Systeme de detection et de sensibilisations aux emails de Phishing

On va un emails publics : securite@secure-account-verify.com
Maintenant on a le mail en question envoyé par cette addresse :

Objet : Urgent , votre compte sera verrouillé
Cher utilisateur ,
Nous avons remarqué une activité suspecte sur votre compte.
Pour éviter la suspension de votre compte veuillez vérifier vos informations immédiatement
Veuillez vérifier maintenant : *http://secure-account-verify[.]com*
Le défaut de vérification dans les 24 h entraînera un blocage permanent du compte
Cordialement,
Equipe de sécurité

Remarque : tout de suite que le nom de domaine de l'adresse email correspond exactement au lien suspect (secure-account-verify.com), ce qui confirme que l'expéditeur a créé ce domaine uniquement pour cette arnaque

Le code source de l'email :
Delivered-To: admin@raff-store.com
Return-Path: <mailer-daemon@vps-hack-99.net>
Received: from vps-hack-99.net (vps-hack-99.net. [203.0.113.88])
by mx.raff-store.com with ESMTP id 987654321

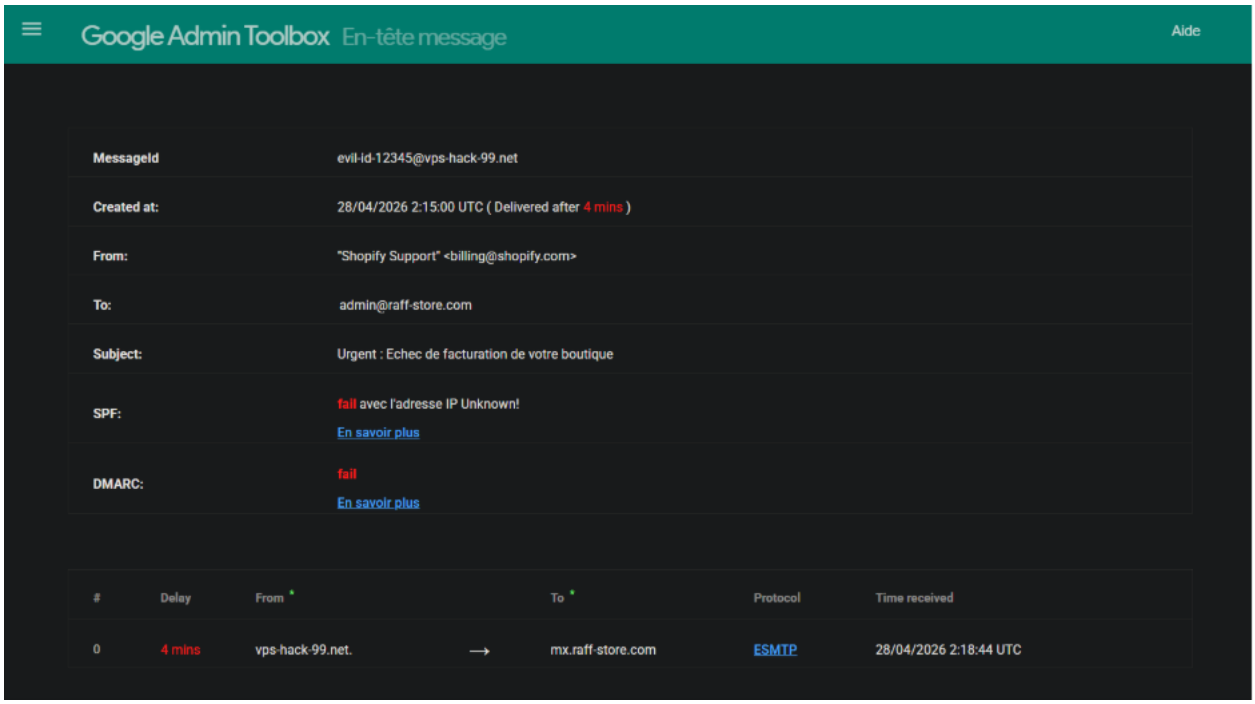
for <admin@raff-store.com>;
Tue, 28 Apr 2026 02:18:44 +0000
Authentication-Results: mx.raff-store.com;
spf=fail (mx.raff-store.com: domain of mailer-daemon@vps-hack-99.net does not designate 203.0.113.88 as permitted sender);
dmarc=fail (p=REJECT sp=REJECT dis=NONE) header.from=shopify.com
From: "Shopify Support" <billing@shopify.com>
To: admin@raff-store.com
Subject: Urgent : Echec de facturation de votre boutique
Date: Tue, 28 Apr 2026 02:15:00 +0000
Message-ID: <evil-id-12345@vps-hack-99.net>
Content-Type: text/plain; charset=UTF-8

Cher administrateur,
Le dernier paiement pour le forfait de votre boutique a échoué.
Pour éviter la suspension immédiate de vos ventes et la déconnexion de vos applications, veuillez mettre à jour vos informations de facturation.
Vérifier maintenant : http://shopify-secure-billing-update[.]com/login
Le défaut de vérification entraînera la fermeture de la boutique.
Cordialement,
L'équipe de facturation

Analyse du code source

- On colle le code dans le site d'analyse d'en tete : https://toolbox.googleapps.com/apps/messageheader/

Résultats :



1. Analysons les en tetes des emails

- Primo on a Usurpation d'identité (Spoofing) : La ligne From affiche l'adresse légitime "Shopify Support" <billing@shopify.com>, mais l'historique de routage montre que le message provient en réalité du serveur vps-hack-99.net.

- Apres on a une echec d'authentification : les protocoles de sécurité SPF et DMARC affichent un statut Fail (en rouge). Cela prouve techniquement que le serveur d'origine n'a aucune autorisation de la part de Shopify pour envoyer des emails en leur nom

2. Inspecter le domaine et les liens de l'expéditeur

- Domaine réel expéditeur : Le domaine d'origine vps-hack-99.net n'a aucun lien commercial avec la plateforme e-commerce officielle
- Analyse du lien d'action : Le lien inclus dans le message (http://shopify-secure-billing-update[.]com/login) est frauduleux. Il utilise le protocole HTTP non sécurisé et emploie la technique du "typosquatting" (créer un faux nom de domaine qui ressemble au vrai pour tromper l'œil de l'utilisateur)

3. Identification des indicateurs de Phishing

- Pression psychologique et urgence : Utilisation de mots alarmants comme "Urgent" "suspension immédiate", et "fermeture de la boutique" pour forcer l'action sans réflexion

- Salutation générique : Le message commence par "Cher administrateur" au lieu d'utiliser le prénom du gérant ou le nom exact de la boutique, prouvant qu'il s'agit d'un envoi de masse automatisé

- Demande d'action inhabituelle : Obliger l'utilisateur à cliquer sur un lien externe spécifique pour mettre à jour des données bancaires, ce que les plateformes légitimes demandent rarement de faire directement depuis un email

4. Le risque d'email

Niveau de risque : élevé
Justifications : Cette attaque cible spécifiquement les accès administrateur et les données de facturation de l'entreprise. Si un employé clique et entre ses identifiants, les pirates prennent le contrôle total de la plateforme de vente, pouvant détourner les paiements ou détruire la base de données clients

5. Documentation des resultats pour l'entreprise

L'analyse technique de l'email signalé démontre une tentative avérée de hameçonnage (phishing). Bien que le message affiche l'adresse officielle de facturation de la plateforme e-commerce, l'analyse des en-têtes (échec des vérifications SPF et DMARC) prouve qu'il a été expédié depuis un serveur malveillant usurpant cette identité. Le message utilise la manipulation psychologique (menace de suspension) pour rediriger l'administrateur vers un site web falsifié dans le but de voler ses identifiants de connexion et ses informations financières

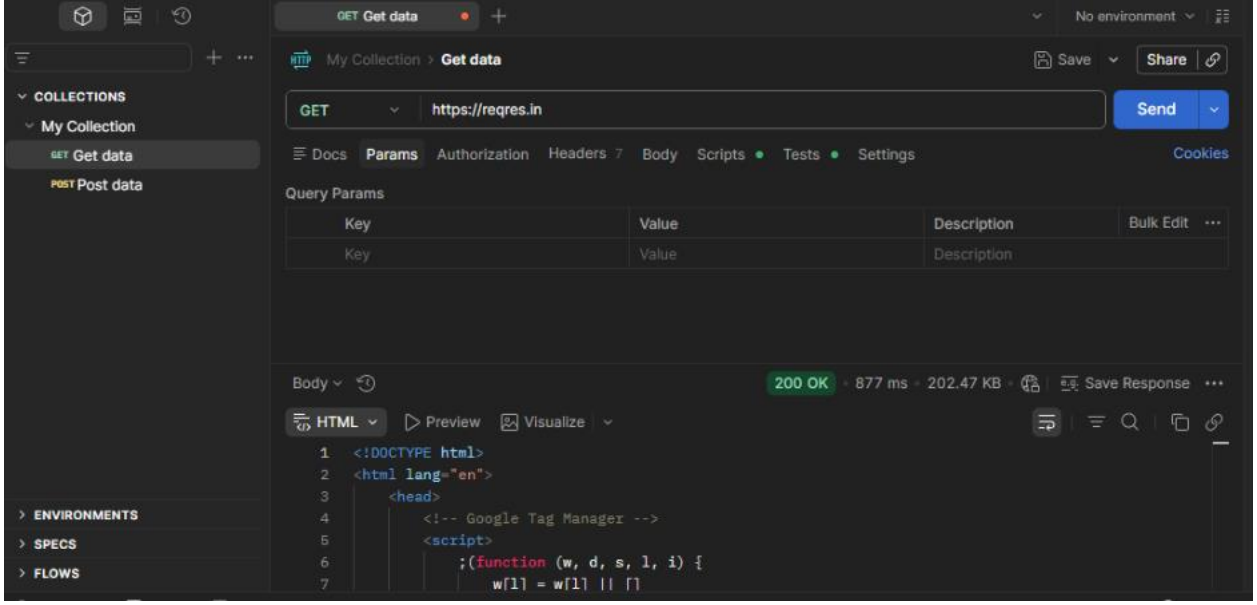
6. Création des directives de prevention et de sensibilisation

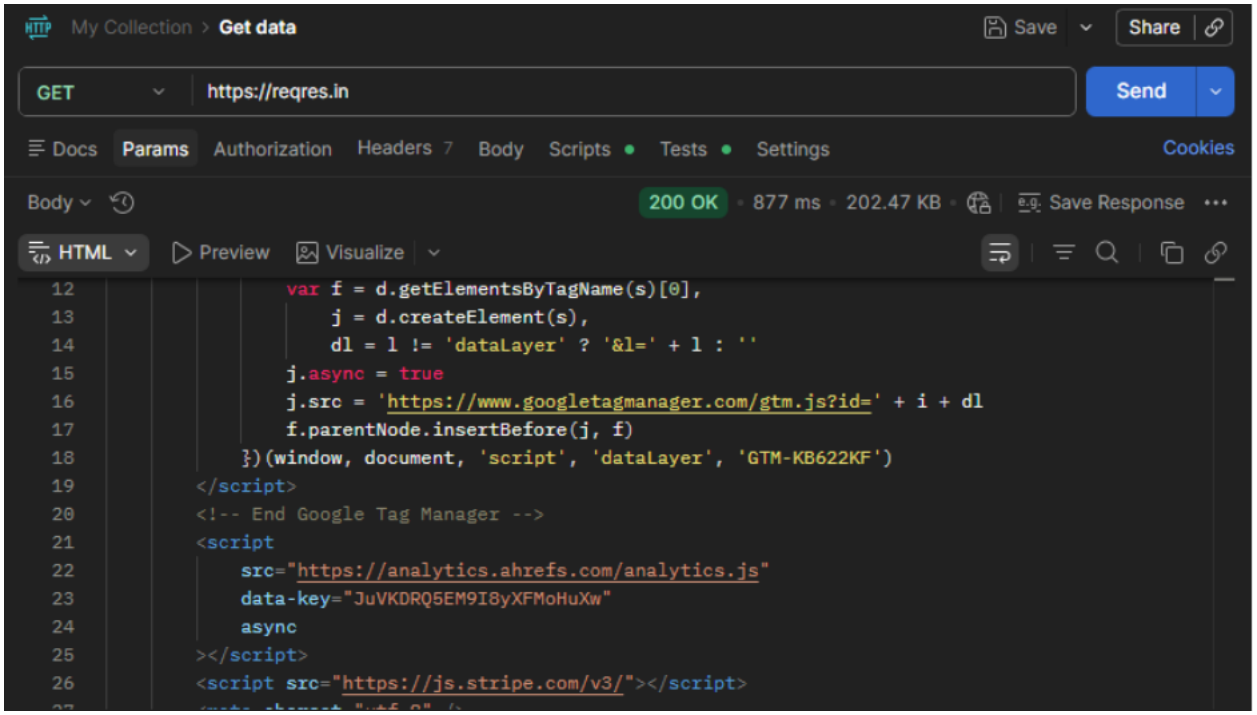
Pour protéger l'entreprise contre ces menaces à l'avenir, les employés doivent appliquer les 4 règles d'or suivantes :

- La règle du détachement : Les entreprises légitimes ne suppriment jamais un compte du jour au lendemain par email. Face à un message urgent ou menaçant, ne paniquez pas et prenez le temps d'analyser la situation.
- La règle de la vérification de l'expéditeur : Ne vous fiez jamais au nom affiché. Cliquez toujours sur le nom de l'expéditeur pour révéler l'adresse email complète et vérifier qu'elle correspond exactement au domaine officiel.
- La règle du chemin direct : Ne cliquez jamais sur un lien de facturation ou de connexion reçu par email. Ouvrez plutôt votre navigateur, tapez vous-même l'adresse officielle du service (ex: www.shopify.com), connectez-vous à votre espace et vérifiez s'il y a de réelles notifications d'erreur de paiement.
- La règle du double verrou (Technique) : Activez l'Authentification à Double Facteur (2FA) sur tous les comptes professionnels. Ainsi, même si un employé se fait piéger et donne son mot de passe, le pirate ne pourra pas se connecter sans le code temporaire envoyé sur le téléphone de l'employé

TASK 3
FUTURE_CS_03 API SECURITY RISK ANALYSIS

Cible Analysé : https://reqres.in
Endpoint testé dans Postman ; Get https:// reqres.in/api/users (recuperation de la liste des utilisateurs)





Résultats de l'inspection (Postman / Ooutils de développement) :

- Exigences d'authentification : Aucune. La requête fonctionne parfaitement sans aucun jeton (Token) ni mot de passe

- En-têtes de réponse (Headers) : Le serveur renvoie Access-Control-Allow-Origin: * et X-Powered-By: Express

- Données de réponse (Body) : L'API renvoie un fichier JSON en clair contenant des informations personnelles : identifiants, prénoms, noms de famille et adresses email

Risque 1 : Absence d'Authentification sur les Données Sensibles

- **Le problème technique :** L'endpoint de l'API qui distribue les informations des utilisateurs est public. Aucun mécanisme d'authentification (comme un jeton JWT ou OAuth) n'est exigé pour lire la réponse

- **Explication commerciale :** C'est comme si le registre contenant la liste de tous vos clients (noms et emails) était posé sur le comptoir du magasin, accessible à quiconque entre dans la boutique sans même avoir à se présenter. Pour une boutique en ligne, laisser une telle API ouverte signifie que n'importe quel concurrent ou individu malveillant peut aspirer et voler l'intégralité de votre base de données clients en quelques secondes, ce qui détruirait la confiance de vos acheteurs

- **Gravité du risque : Élevée (Critique)**
- **Mesures de remédiation :** * Verrouiller cet accès en implémentant une authentification stricte (ex: exiger un *Bearer Token* valide dans l'en-tête de la requête) S'assurer que seuls les administrateurs de la plateforme possèdent les droits pour interroger la liste complète des utilisateurs.

Risque 2 : Mauvaise Configuration du Partage (CORS)

- Le problème technique : L'en-tête de réponse indique Access-Control-Allow-Origin: *

- Explication commerciale : L'API autorise n'importe quel site internet externe à venir interroger et utiliser ses données. Si un de vos clients est connecté à son compte sur votre site web et visite simultanément un site piégé, ce site piégé a l'autorisation technique de venir lire les données du client à travers l'API

- Gravité du risque : Moyenne
- Mesures de remédiation :

Restreindre la politique CORS. Remplacer l'astérisque (*) par les adresses web exactes de l'entreprise (ex: https://www.mon-entreprise.com)

Risque 3 : Fuite d'Informations Technologiques

- **Le problème technique :** L'API renvoie l'en-tête X-Powered-By: Express

- **Explication commerciale :** Votre système annonce publiquement la technologie exacte avec laquelle il a été construit (ici, le framework *Express*). Cela permet à un attaquant de gagner du temps en filtrant ses attaques pour n'utiliser que celles qui ciblent spécifiquement cette technologie

- **Gravité du risque : Faible**
- **Mesures de remédiation :**

Demander à l'équipe de développement de supprimer l'en-tête X-Powered-By dans la configuration du framework pour masquer l'architecture technique aux yeux du public